

Phishing Simulation Plan (HPAP)

1. Simulation Scenario

For this simulation, students receive an email that appears to come from Hocking College IT. The message says their student account needs to be verified and warns that access to college services may be limited if they do not act soon. The email includes a simulated verification link that takes users to a safe training page instead of a real login page.

This scenario reflects a common phishing attack where attackers try to steal login credentials by sending users to a fake login page. In a real attack, a student may believe they are logging into a normal college system, but their username and password could be sent to the attacker instead.

Why it is believable:

This message is believable because it uses the school name, creates urgency, and connects to services students use often, such as college email, Blackboard, assignments, and student accounts. Students are used to receiving account-related messages, so a fake verification email could seem real if they do not slow down and check the warning signs.

If students click the link, they would be taken to a safe simulated landing page that explains this was part of a phishing awareness exercise. The page would point out the warning signs in the message and remind students how to report suspicious emails in the future.

Target Audience:

Students

2. Sample Phishing Message

Subject: Urgent: Account Verification Required

Message:

Dear Student,

Your Hocking College account needs to be verified to avoid possible access restrictions. Please use the link below to confirm your account information.

[Verify Account]

If your account is not verified, you may lose access to college email, Blackboard, and student services.

Thank you,
Hocking College IT

Subtle phishing indicators:

This message includes urgency, a generic greeting, and a verification link. These are common warning signs that students should learn to recognize before clicking. The message also pressures the user by suggesting they may lose access to important school services.

3. Expected User Behavior

Users may respond to the message in several ways:

Click the link:

This indicates risk because the user interacted with the phishing message without verifying it first.

Enter information on the simulated page:

This indicates higher risk because it shows the user may be willing to submit login information on a suspicious page. In the simulation, no real passwords or personal data would be stored.

Ignore the message:

This avoids immediate harm, but it does not help the college identify or respond to phishing attempts.

Report the message:

This is the preferred behavior because it shows the user recognized the message as suspicious and took action.

Clicking the link or submitting information would show that more training may be needed. Reporting the message would show successful awareness because the user noticed the warning signs and followed the correct response process. Ignoring the message is better than falling for the phishing attempt, but reporting is more useful because it helps the organization respond to possible threats.

4. Metrics & Measurement

The organization could measure the simulation using several metrics:

Click Rate:

The percentage of users who clicked the simulated phishing link. A high click rate shows that users may be reacting too quickly to urgent messages without checking them carefully.

Submission Rate:

The percentage of users who entered information or pressed submit on the simulated page. This would be the highest-risk behavior because it shows that users may be willing to enter credentials into a fake page. The simulation should only record that a submission happened, not the actual information typed.

Report Rate:

The percentage of users who reported the suspicious email. A higher report rate shows stronger security awareness and helps the organization respond faster to real phishing attempts.

Ignore Rate:

The percentage of users who did not click, submit information, or report the email. Ignoring the message is safer than clicking, but it still does not help the college track or respond to suspicious activity.

These metrics can help improve future cybersecurity training. For example, if many students click the link, future training could focus on checking links, recognizing urgency, and slowing down before responding. If few students report the message, training could explain how to report suspicious emails and why reporting matters.

After reviewing the results, the college could adjust future training based on the weakest areas. A high click rate would show that students need more practice recognizing urgency and suspicious links. A low report rate would show that students may need clearer instructions on how to report suspicious emails. Future simulations could then test whether those areas improved over time.

5. Ethical & Safety Considerations

The simulation should be approved and clearly limited to an educational purpose. It should be designed to measure awareness without causing harm, panic, or embarrassment. The message should be realistic enough to teach users, but it should not threaten serious consequences or create unnecessary fear.

The simulation should not collect real passwords, personal information, or sensitive student data. If a user enters information on the simulated page, the system should only record that a submission occurred. The typed information should not be saved.

After the simulation, users should receive a clear follow-up explaining that the message was part of a training exercise. The follow-up should point out the warning signs, such as urgency, the generic greeting, and the verification link. This helps make the simulation a learning opportunity instead of just a trick.

Results should be used for training and awareness, not to punish or shame individual students. Reports should focus on overall group trends instead of publicly identifying individual students. This keeps the simulation focused on awareness and improvement rather than blame.

Overall, this simulation supports the Hocking Phishing Awareness Program by safely testing user behavior, identifying risky patterns, and improving cybersecurity awareness over time.